BOOKFINANCE

ศูนย์บัญชาการการเงินที่ปกป้องทุนก่อนให้บอทเทรดเงินจริง

NFR และความปลอดภัย

รหัสเอกสาร	BTR-DOC-03
ฉบับ	0.1
วันที่	2026-10-08
สถานะ	ร่างเพื่อพิจารณา

เอกสารภายในฉบับร่าง — ใช้ประกอบการพัฒนาและดูแลระบบ

สารบัญ

1. NFR พร้อมเป้าหมายที่วัดได้

2. Security controls

3. Privacy / PDPA

4. Observability

5. Backup / DR

การอนุมัติ

แหล่งข้อมูล

BookFinance — NFR และความปลอดภัย

1. NFR พร้อมเป้าหมายที่วัดได้

ID	หมวด	ข้อกำหนด	เป้าหมาย	หลักฐาน/สถานะ
NFR-01	Capital safety	ไม่มีคำสั่งเงินจริงขณะ `POLY_DRY_RUN=true` หรือ kill switch ACTIVE	0 คำสั่ง	`test_kill_switch.py` (13 test), `test_safety_filters.py` (29), `test_mainnet_default.py`
NFR-02	Capital safety	Futures mainnet ถูกปฏิเสธแม้มี credential, leverage ≤ 5x, isolated margin	100%	`test_futures_safety.py` (15), `README.md`
NFR-03	Capital safety	Kill switch ทำงานเมื่อ paper drawdown เกิน 5%	auto-halt	`strategy/RUNBOOK.md` (limit 5%)
NFR-04	Performance	หน้า System auto-refresh	ทุก 30 วินาที	`README.md` Core 5
NFR-05	Performance	เวลาตอบ `/api/command-center`	**[ต้องยืนยัน]** ยังไม่มีการวัด	—
NFR-06	Availability	uptime production	**[ต้องยืนยัน]** ยังไม่มี production	Gate 4 ยังไม่พร้อม
NFR-07	Scalability	ผู้ใช้พร้อมกัน	1 operator; WS จำกัดด้วย `WS_MAX_CLIENTS` **[สมมติฐาน]** เพียงพอ	`backend/internal/config/config.go`
NFR-08	Maintainability	CI ผ่าน lint/format/typecheck/test ทั้ง 3 ชุด	ทุก push	`.github/workflows/ci-cd.yml`
NFR-09	Correctness	Order ที่ผลไม่ชัดต้อง reconcile ด้วย client order ID ไม่ส่งซ้ำ	0 order ซ้ำ	`order_reconcile_test.go`, `bitkub_reconcile_test.go`
NFR-10	Correctness	Backtest ไม่มี look-ahead bias	แก้แล้วบางส่วน; ATR anchoring ยังค้าง (P1)	`docs/UPGRADE-PLAN.md`

2. Security controls

ID	Control	รายละเอียด	หลักฐาน
SEC-01	Route access matrix	ทุก route มีระดับ public/user/admin/service; test อ่าน route จริงจาก source	`route_access.go`, `routes_access_test.go`, `test_route_access_matrix.py`
SEC-02	Strategy auth fail closed ใน production	route ที่เปลี่ยนสถานะต้องมี auth	`test_require_auth_production.py`, `test_mutating_routes_auth.py`
SEC-03	Kill-switch reset ต้องยืนยันตัวตน	`POST /api/poly-paper/reset-kill-switch`	`test_safety_reset_auth.py`
SEC-04	Proxy `/strategy-api`	backend ตรวจ session, เติม `AUTH_TOKEN` ฝั่ง server, write เป็น admin	`strategy_proxy_test.go`, `strategy-services-auth.test.ts`
SEC-05	Login lockout	lock ต่อคู่ (email, IP), หน่วงเวลาต่อบัญชี; เชื่อ header IP เฉพาะจาก `TRUSTED_PROXIES`	`login_lockout_test.go`, `client_ip.go`
SEC-06	Registration gated	ควบคุมด้วย `ALLOW_REGISTRATION`, `REGISTRATION_INVITE_CODE`	`registration_test.go`
SEC-07	Network exposure	prod ผูกพอร์ตบริการกับ loopback; เปิดเฉพาะ Caddy	`docker-compose.prod.yml`

ID	Control	รายละเอียด	หลักฐาน
SEC-08	Secret handling	secret อยู่ใน env/GitHub secrets; ใช้ Infisical (`.infisical.json`) **[ต้องยืนยัน]** ว่าเป็น store หลัก	`RUNBOOK.md`, `.infisical.json`
SEC-09	Exchange API keys	เก็บใน DB (migration 006)	**[ต้องยืนยัน]** การเข้ารหัสด้วย `ENCRYPTION_KEY`
SEC-10	Token ไม่รั่วไปโดเมนอื่น	httpx hook แนบ token เฉพาะ `BACKEND_API_BASE` / `PAPER_API_BASE`	`strategy/app/backend_auth.py`, `test_backend_auth.py`
SEC-11	Supply chain	GitHub Actions ภายนอก pin ด้วย SHA (บางตัว)	`.github/workflows/ci-cd.yml`

ช่องโหว่ที่ทราบ: ยังไม่มี PenTest หรือ dependency scanning ใน CI **[ต้องยืนยัน]**

3. Privacy / PDPA

- ข้อมูลส่วนบุคคลที่เก็บ: อีเมลและรหัสผ่าน (hash **[ต้องยืนยัน]** อัลกอริทึม) ของผู้ใช้, ข้อมูลการเงินส่วนตัว (accounts, transactions, net worth) และ Telegram user
- ผู้ใช้ปัจจุบันเป็นเจ้าของคนเดียว จึงยังไม่มีภาระ PDPA ต่อบุคคลที่สาม หากเปิด multi-user ต้องมีนโยบายความเป็นส่วนตัว การขอความยินยอม และการลบข้อมูล **[สมมติฐาน]**
- ห้าม commit `.env` หรือ API key (`RUNBOOK.md`)

4. Observability

สัญญาณ	ที่มา
Health	`GET /api/health` (backend และ strategy), `/api/real-grid/health`
Metrics	Prometheus (`monitoring/prometheus.yml`)
Logs	`docker compose logs`, strategy รองรับ `LOG_FORMAT=json`, `LOG_LEVEL`
Decision log	`scripts/monitor.py` + `docs/EVIDENCE_LOG.md`
Alert	kill-switch alert ผ่าน webhook/Telegram (`webhook_notifier.py`)

Grafana dashboard และ alert rule จริง **[ต้องยืนยัน]** (Gate 4 ยังไม่ติ๊ก "Monitoring/alerting configured")

5. Backup / DR

- `PRODUCTION.md` §Step 6 ให้ script `pg_dump` + copy Redis `dump.rdb` เก็บ 7 วัน — เป็นขั้นตอนที่ต้องตั้งเอง ไม่มีหลักฐานว่าตั้งแล้ว **[ต้องยืนยัน]**
- RPO/RTO ยังไม่กำหนด **[ต้องยืนยัน]**; ข้อเสนอ **[สมมติฐาน]** RPO 24 ชม. / RTO 4 ชม. สำหรับระบบผู้ใช้คนเดียว
- Migration ส่วนใหญ่มีไฟล์ `.down.sql`; ไฟล์ `013`, `014`, `018`, `019`, `020` ไม่มี down — ถือเป็น one-way
- ข้อควรระวัง: job deploy รัน `docker system prune -af --volumes` หลัง `up` ซึ่งลบ volume ที่ไม่ได้ผูกกับ container ที่รันอยู่ **[ต้องยืนยัน]** ว่าไม่กระทบ `postgres_data`

การอนุมัติ

บทบาท	สถานะ	วันที่	ลงนาม
Solution Architect (Book Dev)	รอตรวจ	—	[ต้องยืนยัน]
Security reviewer	รอตรวจ	—	[ต้องยืนยัน]

แหล่งข้อมูล

- `README.md`, `PRODUCTION.md` (§Security Checklist, §Backups), `strategy/RUNBOOK.md`
- `docs/READINESS_CHECKLIST.md`, `docs/UPGRADE-PLAN.md`
- `backend/internal/adapter/http/` (route_access, auth_handler, client_ip, strategy_proxy และ test)
- `strategy/tests/` (kill switch, safety filters, futures safety, route access, auth)
- `docker-compose.prod.yml`, `Caddyfile`, `.github/workflows/ci-cd.yml`, `backend/migrations/`